UNIVERSIDAD POLITÉCNICA DE SAN LUIS POTOSÍ
Ingeniería en Tecnologías de la Información

CNO IV — REPORTE DE LABORATORIO

File Path Traversal: Secuencias de traversal eliminadas con decodificación URL superflua

Actividad 10 — Road to Hall of Fame

PortSwigger Web Security Academy
portswigger.net/web-security/file-path-traversal/lab-superfluous-url-decode

---

Alumno: Jorge Abraham Castelo Curioca

Materia: CNO IV

Docente: Mtro. Servando López Contreras

Periodo: Segundo Parcial

Documento: Path Traversal 4 Actividad 10.pdf

1. Ficha técnica del laboratorio

Nombre del laboratorio	File path traversal, traversal sequences stripped with superfluous URL-decode
Nivel	Practitioner
Tipo de explotación	File Path Traversal / Directory Traversal — evasión de filtro mediante doble codificación URL
Objetivo del laboratorio	Evadir el filtro de saneamiento de la aplicación para recuperar el contenido del archivo de sistema `/etc/passwd`.

2. Explicación técnica de la vulnerabilidad

La aplicación recibe el nombre del archivo a mostrar a través del parámetro `filename` y, como mecanismo de defensa, elimina del valor recibido cualquier secuencia literal `../` antes de usarla para localizar el archivo en el servidor. El problema reside en el orden en que se aplican las operaciones: el servidor primero decodifica la URL una vez, después ejecuta el filtro que busca y elimina `../`, y finalmente vuelve a aplicar una **segunda decodificación URL** sobre el resultado —un paso que resulta innecesario o "superfluo" para el funcionamiento normal de la aplicación, pero que abre la puerta a la evasión del filtro.

Al codificar las secuencias de traversal utilizando una doble codificación porcentual (por ejemplo, `%25` en lugar de `%`), la primera decodificación convierte `%252f` en `%2f`, una cadena que el filtro no reconoce como `../` y por lo tanto deja intacta. Inmediatamente después, la segunda decodificación —superflua y no anticipada por los desarrolladores— convierte ese `%2f` remanente en el carácter `/`, reconstruyendo la secuencia de salto de directorio que el filtro debía haber bloqueado. De esta forma, el ataque atraviesa la validación sin ser detectado.

3. Procedimiento paso a paso

1. **Identificación del punto de entrada.** Se inició el laboratorio y, mediante Burp Suite configurado como proxy del navegador, se identificó que la galería de productos carga cada imagen a través de una petición `GET /image?filename=<archivo>`, confirmando que el parámetro `filename` es la entrada controlada por el usuario que determina el archivo servido.

2. **Construcción del payload con doble codificación URL.** Dado que el laboratorio elimina las secuencias `../` antes de un segundo proceso de decodificación, se construyó un payload que codifica el carácter `%` como `%25`, de manera que la barra de la secuencia de traversal quede oculta durante la fase de filtrado:

   ```
   filename=..%252f..%252f..%252fetc/passwd
   ```

3. **Envío de la petición modificada.** La petición se envió al servidor desde el Repeater de Burp Suite. En la respuesta, el servidor devolvió con código `200 OK` el contenido completo del archivo `/etc/passwd`, incluyendo las cuentas del sistema (`root`, `daemon`, `bin`, `peter`, `carlos`, `user`, `elmer`, `academy`, entre otras), confirmando que el filtro fue evadido exitosamente.

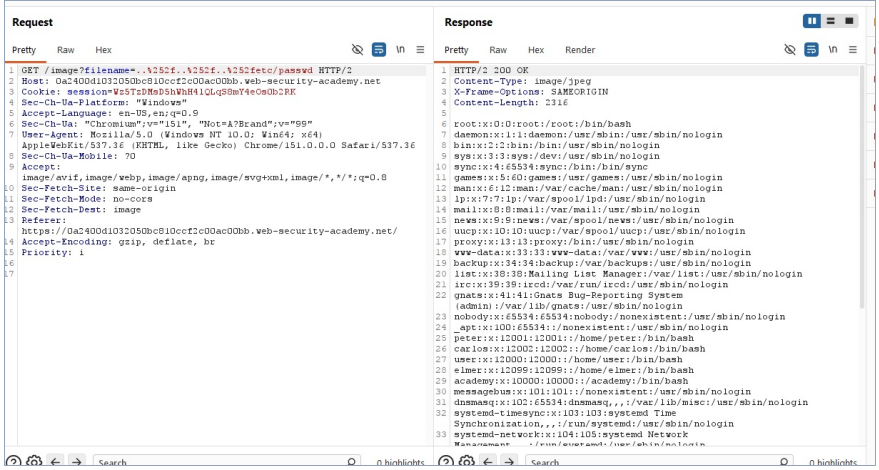


Figura 1. Burp Suite – Repeater: solicitud con el payload `..%252f..%252f..%252fetc/passwd` y respuesta del servidor mostrando el contenido íntegro de /etc/passwd.

4. **Confirmación de la explotación.** Al regresar a la aplicación, la plataforma de PortSwigger Web Security Academy marcó el laboratorio como resuelto, confirmando de manera oficial el éxito de la explotación.

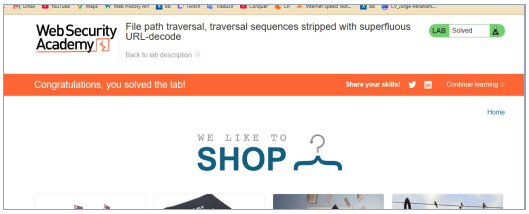


Figura 2. Confirmación "Lab Solved" otorgada por PortSwigger Web Security Academy tras la explotación exitosa.

4. Explicación del payload

```
..%252f..%252f..%252fetc/passwd
```

El payload está compuesto por tres repeticiones del bloque `..%252f` seguidas del nombre del archivo objetivo. Cada bloque representa, tras dos decodificaciones sucesivas, un salto de directorio completo (`../`): la primera decodificación que realiza el servidor transforma `%252f` en `%2f` —cadena que el filtro antitraversal no identifica como peligrosa, por lo que la deja pasar sin modificarla—, y la segunda decodificación, aplicada después del filtrado, transforma ese `%2f` remanente en el carácter `/`, completando así la secuencia `../` que originalmente se intentaba bloquear. Al repetir el bloque tres veces se obtienen tres saltos reales hacia directorios superiores, suficientes para salir de la carpeta de imágenes y alcanzar la raíz del sistema de archivos, desde donde se referencia directamente `etc/passwd`.

5. Mitigación recomendada

- Decodificar la entrada una única vez, antes de aplicar cualquier validación, y nunca volver a decodificarla después del proceso de saneamiento.
- Sustituir la estrategia de "lista negra" (buscar y eliminar `../`) por una validación de "lista blanca" que solo acepte nombres de archivo previamente autorizados.
- Utilizar las funciones nativas del sistema operativo o del lenguaje de desarrollo para canonicalizar la ruta resultante y verificar que el archivo final resida dentro del directorio base permitido antes de abrirlo.
- Ejecutar el proceso que sirve los archivos bajo el principio de mínimo privilegio, de modo que, aun si el filtro vuelve a fallar, el impacto de una posible explotación quede limitado.